

Tabletop Exercise: Insider Theft of High-Net-Worth Client Data

Revised PDF package integrating evaluation feedback

Exercise type: Discussion-based cyber tabletop exercise

Audience: Executive leadership, Security Operations, Incident Response, Legal, HR, Privacy, Compliance, Client Relationship Management, Communications, and Technology leadership

Suggested duration: 90 minutes, with optional 30-minute technical deep-dive

Version: Revised scenario guide generated July 13, 2026

Introduction

This tabletop exercise tests the organization's ability to detect, assess, contain, investigate, and manage an insider-driven theft of sensitive private-banking client information. The scenario is based on a structured cyber scenario describing a departing employee with legitimate access who performs an unusually large export of client-book data and uses, or attempts to use, an unapproved external storage device.

The revised version strengthens evidentiary realism, separates confirmed facts from investigative hypotheses, adds concrete technical playbook decisions, and expands the MITRE ATT&CK mapping to cover the insider activity lifecycle without overstating unsupported techniques.

Facilitator posture

Participants should treat the scenario as credible but incomplete. The purpose is to test decision-making under uncertainty, not to force a single technical conclusion before sufficient evidence exists.

Exercise Overview

Field	Detail
Scenario title	Insider Theft of High-Net-Worth Client Data
Exercise type	Discussion-based tabletop exercise
Primary audience	Executive leadership, Security Operations, Incident Response, Digital Forensics, Insider Risk, Legal, HR, Privacy, Compliance, Client Relationship Management, Communications, Identity and Access Management, Endpoint Engineering, Data Governance/DLP
Suggested duration	90 minutes; optional extension to 120 minutes for technical forensics and evidence scoring
Scenario basis	Structured cyber scenario / STIX-style report: "TTX Scenario 5 - Insider theft of high-net-worth client data"
Core learning theme	Coordinated insider-risk response involving legitimate access, abnormal export behavior, removable-media evidence, client-impact assessment, and regulator-ready documentation
Recommended facilitation format	Facilitator introduces one inject at a time, asks the team to maintain a fact / hypothesis / decision log, and scores each checkpoint using the rubric included in this guide.

Evaluation Feedback Integrated in This Revision

The following improvements are explicitly integrated from the evaluation JSON to improve realism, consistency, cyber accuracy, training value, and objective assessment.

Feedback area	Concrete integration in the revised TTX
Realism	Specifies the data source as the Private Banking Client Relationship Management repository, describes the bulk export mechanism, identifies supporting telemetry, and treats USB exfiltration as suspected until validated by forensics or recovered media.
Coherence and consistency	Each inject separates confirmed facts, suspected or likely facts, and working hypotheses so participants can distinguish evidence from assumptions.
Cyber accuracy	Expands the ATT&CK mapping across account misuse, discovery, collection, local staging, and physical-media exfiltration, while marking confidence levels and excluding unsupported techniques.
Training value	Adds playbook execution criteria, containment triggers, evidence-preservation decision points, legal-hold checkpoints, and operational thresholds for participants to evaluate.
Structural completeness	Adds formal success metrics, scoring criteria, facilitator checkpoints, and a repeatable evaluation rubric for consistent observation and after-action reporting.

Scope

The exercise covers the full cross-functional response lifecycle from first detection through containment, investigation, notification analysis, executive briefing, client-risk management, and lessons learned.

- Detection of suspicious customer-data exports by a departing employee.
- Triage and validation of potential insider misuse involving legitimate access.
- Containment of user access, workstation, removable media, data repositories, and communication channels.
- Coordination across Security, Legal, HR, Privacy, Compliance, Communications, and business leadership.
- Decisions on account restriction, device preservation, legal hold, employee interview, civil action, and law-enforcement referral.
- Client-impact assessment and jurisdiction-specific regulator-notification considerations.
- Executive, employee, client, and external communications management.
- Post-incident control improvements for offboarding, access governance, DLP, endpoint controls, and monitoring.

The exercise does not require participants to perform live technical remediation. It is designed to validate roles, escalation paths, decision authority, technical evidence handling, and cross-functional coordination.

Objectives

1. Recognize indicators of insider misuse involving legitimate access to sensitive private-banking client data.
2. Assess severity and business impact using verified facts, data sensitivity, number of clients affected, and regulatory exposure.
3. Coordinate Security, Legal, HR, Privacy, Compliance, Communications, and business leadership during an active offboarding-related insider-risk case.

4. Make defensible decisions on account restriction, endpoint isolation, device preservation, legal hold, employee engagement, and chain of custody.
5. Distinguish confirmed facts from suspected activity and working hypotheses throughout the investigation.
6. Evaluate regulatory, contractual, confidentiality, and client-notification obligations without prematurely asserting external disclosure.
7. Demonstrate executive escalation and communications control for a high-trust, relationship-driven business line.
8. Identify improvements to monitoring, removable-media controls, privileged access, offboarding controls, abnormal export analytics, and insider-risk governance.
9. Map the scenario to relevant MITRE ATT&CK tactics and techniques with appropriate confidence levels and detection evidence.

Assumptions

- The suspected employee is a relationship manager or equivalent private-banking role with legitimate access to client-book data.
- The employee is in the final week of employment and retains normal business access at exercise start.
- The organization operates centralized logging for client-data exports, identity events, endpoint activity, DLP, and removable-media telemetry.
- The authoritative data source is a Private Banking Client Relationship Management repository that stores client contact details, relationship notes, product associations, portfolio-related summaries, risk preferences, KYC tags, and servicing contacts.
- The export mechanism is the standard CRM reporting/export function, which can generate CSV or spreadsheet files from saved client-book reports.
- Legal, HR, Privacy, Compliance, Security, and business leadership are available for urgent consultation.
- Not every fact is known at the start. Participants should update their decisions as facts evolve.

Evidence Confidence Model

Confidence label	Meaning	Facilitator expectation
Confirmed fact	Validated by a reliable source such as application audit logs, EDR telemetry, forensic artifacts, DLP events, IAM logs, recovered media, documented business records, or direct admission.	Participants may base immediate containment, preservation, and escalation decisions on these facts.
Suspected / likely fact	Supported by correlation or partial evidence but not yet fully proven; for example, USB insertion near the export window before full forensic acquisition is complete.	Participants should act to prevent further loss while documenting uncertainty and required validation steps.
Working hypothesis	A plausible explanation that guides investigation but is not evidence; for example, client poaching, competitor misuse, or onward disclosure.	Participants should not use hypotheses as public or employee-facing statements unless confirmed.

Rules of Engagement

- This is a no-fault learning exercise.
- Use real roles, authorities, escalation paths, and policies where possible.
- Discuss actions based on realistic resource constraints and current tooling.
- Treat scenario details as credible unless an inject changes them.
- Maintain a fact / hypothesis / decision log throughout the exercise.
- Do not confront or notify the suspected employee in the scenario until Legal and HR dependencies are addressed.
- Do not fight the scenario; use ambiguity as part of the exercise.
- Real-world incidents take priority over the exercise.

Participant Roles

Role group	Recommended participants	Primary exercise responsibilities
Executive / Crisis Leadership	CISO or delegate; COO or business executive; Head of Private Banking; Crisis Manager; Board liaison where applicable	Set risk appetite, authorize crisis posture, approve external messaging, ensure business impact is understood, and determine when the event becomes an enterprise-level crisis.
Operational / Control Functions	SOC; Incident Response; Digital Forensics; Insider Risk / Fraud / Monitoring; Legal Counsel; HR / Employee Relations; Privacy; Compliance / Regulatory Affairs; Communications	Validate facts, preserve evidence, coordinate employee-handling decisions, conduct breach assessment, prepare regulator-ready chronology, and control communications.
Technical / Business Support	IAM; Endpoint Engineering; DLP / Data Governance; CRM application owner; Private-Banking Operations; Client Relationship Management leadership; Records Management	Provide system logs, execute access restrictions, validate data scope, preserve endpoints and media, identify affected clients, and maintain business continuity.

Scenario Summary

Monitoring identifies an unusually large export of high-net-worth client records performed by a departing relationship manager during the employee's final week of employment. The export is executed using legitimate credentials through the standard CRM reporting function, but the record volume, timing, out-of-portfolio access, and offboarding context are materially outside the employee's baseline behavior.

Endpoint telemetry later shows an unapproved removable storage device connected to the employee's workstation near the time the export file was created. At first, only the device connection is confirmed; copying to removable media is suspected but not yet fully proven. Investigators must validate whether the exported client data was staged locally, copied to USB, emailed, uploaded to cloud storage, printed, or otherwise disclosed.

The incident rapidly becomes a cross-functional matter involving confidentiality, employee-rights considerations, evidentiary preservation, client trust, regulatory exposure, and potential civil or criminal action. The organization must avoid premature conclusions while still acting quickly to prevent additional loss.

Technical Scenario Foundation

Element	Exercise detail
Data source	Private Banking Client Relationship Management repository / client-book application. For exercise purposes, this is the authoritative system for high-net-worth client records, relationship notes, portfolio summaries, product associations, contact preferences, and servicing teams.
Export mechanism	Three bulk exports generated through the CRM reporting/export module between 02:47 and 03:12. Export files were downloaded to the managed workstation as CSV/spreadsheet files and named using standard report labels.
Observed anomaly	The employee exported materially more records than baseline, including clients outside their usual portfolio and data fields not required for routine servicing.
Telemetry supporting the activity	CRM application audit logs, SIEM correlation rules, IAM/MFA authentication logs, endpoint EDR file-creation telemetry, DLP classification events, USB device-control telemetry, proxy/CASB logs, email/collaboration audit logs, physical access records, and HR offboarding status.
Initial uncertainty	Export and endpoint file creation are confirmed. USB device insertion is confirmed. Exact file transfer to the USB device is suspected until forensic imaging, file-system artifacts, or recovered media confirm it.

Exercise Timeline and Injects

Inject 1 - Initial Detection

Exercise time: 09:00

Inject

SIEM correlation alerts show that a departing relationship manager exported an unusually large volume of high-net-worth client records from the Private Banking CRM repository. The exports occurred outside normal business hours and include records outside the employee's usual client portfolio. The event is routed to the SOC as an insider-risk lead rather than a malware intrusion.

Confirmed facts

- A named employee is in the offboarding period and remains provisioned with normal CRM access.
- Three CRM bulk export events were recorded between 02:47 and 03:12 using the employee's legitimate credentials.
- The exported report types include client profile details, relationship notes, contact preferences, and product relationship summaries.
- The export volume materially exceeds the employee's 90-day baseline and includes out-of-portfolio client records.
- No malware alert, credential-theft alert, or failed MFA activity has been observed at this stage.

Suspected / likely facts

- The export may be outside normal business need.
- The employee may have used overly broad permissions or report access not required for their role.
- The data set may contain personal information, confidential business information, and relationship-sensitive notes.

Working hypotheses

- Policy violation or careless export for transition work.
- Intentional client-book theft for future solicitation.
- Account misuse by the employee or by another person using the employee's session.
- Broader access-governance failure affecting more users.

Discussion questions

- How is the event classified initially: security incident, insider-risk case, privacy incident, HR matter, or all of the above?
- Which evidence must be preserved before any employee engagement?
- Who must be notified in the first hour, and who has authority to approve containment?

- What threshold triggers immediate account restriction versus controlled monitoring?
- How will the team document confirmed facts separately from hypotheses?

Expected actions

- Open a priority insider-risk/security incident and assign an incident commander or case lead.
- Start a fact / hypothesis / decision log under appropriate privilege where directed by Legal.
- Preserve CRM application logs, export artifacts, IAM/MFA logs, SIEM alerts, DLP events, endpoint telemetry, email/collaboration audit logs, and HR offboarding records.
- Validate data classes, record counts, query filters, report names, timestamps, IP/device identifiers, and whether data was downloaded locally.
- Check for an approved business justification, manager request, client-service need, or offboarding exception.
- Engage Legal and HR before employee contact, disciplinary action, or device seizure.
- Assess whether privileged access, out-of-scope entitlements, or role-based access-control gaps enabled the export.

Facilitator notes

Look for disciplined evidence preservation and careful language. Strong teams should avoid saying “data breach” or “theft” externally before evidence supports the classification, but should still treat the event as high risk because sensitive client data is involved.

Evaluation checkpoint

- Incident severity assigned and rationale documented.
 - Evidence-preservation owner named.
 - Legal and HR engagement identified before employee confrontation.
 - Fact / hypothesis distinction used in the team's first situation report.
-

Inject 2 - Removable Media Indication

Exercise time: 10:00

Inject

Endpoint telemetry shows that an unapproved external storage device was connected to the employee's workstation during the same window in which the CRM export files were created. EDR shows the exported files existed in the local Downloads folder, and device-control telemetry records the USB device serial number. Investigators cannot yet confirm the exact files copied to the device without forensic acquisition.

Confirmed facts

- An unapproved USB storage device was mounted on the employee's workstation as removable media.
- The USB device serial number, vendor ID, product ID, mount time, and workstation asset ID are available in endpoint telemetry.
- CRM export files were created on the local endpoint shortly before or during the USB mount window.
- The employee still has access to corporate systems unless the team acts.
- No confirmed cloud upload, external email, or public leak has been observed.

Suspected / likely facts

- The exported CRM files may have been copied to the USB device.
- The employee may attempt to delete local artifacts or continue exporting data if access remains active.
- Additional channels such as email forwarding, printing, personal cloud storage, or mobile-device sync may also need review.

Working hypotheses

- The USB device was used for exfiltration.
- The USB event is unrelated but still violates policy.
- The employee is preparing client solicitation materials for a competitor.
- A second actor or shared workstation session could be involved, though there is no evidence yet.

Discussion questions

- Do you immediately disable the employee's CRM access, disable all access, or continue controlled monitoring for a defined period?
- What explicit criteria must be met before endpoint isolation or device seizure?
- How should Legal, HR, Security, and the manager coordinate an employee interview?
- What chain-of-custody steps are required for the laptop and any removable media?
- Which telemetry would prove, or disprove, USB file transfer?

Expected actions

- Make a documented containment decision using defined criteria: sensitive export confirmed, no business justification, employee in notice period, and removable-media correlation.
- At minimum, suspend CRM export capability and high-risk data access while Legal/HR approve broader access actions.
- Preserve laptop state, EDR telemetry, USB device history, file-system metadata, browser/download history, shellbags/jumplists where applicable, and DLP alerts.
- Place employee account, mailbox, endpoint, collaboration data, and relevant CRM records under legal hold where appropriate.
- Review printing logs, proxy/CASB logs, webmail activity, email forwarding rules, personal cloud access, and physical access records.
- Identify a client-impact lead to begin preliminary scoping by data field and jurisdiction.

- Prepare a controlled employee-engagement plan that protects evidence and respects employment-law requirements.

Facilitator notes

This inject should create tension between rapid containment and evidentiary completeness. Strong teams should not wait for perfect proof if further loss is likely, but they should document why access restriction is proportionate and what evidence remains unconfirmed.

Evaluation checkpoint

- Containment strategy selected with documented tradeoffs.
- Forensic acquisition and chain-of-custody plan described.
- USB transfer described as suspected unless participants identify proof required.
- Business-continuity owner assigned for active client relationships.

Inject 3 - Intent and Staging Evidence Emerge

Exercise time: 11:30

Inject

Preliminary forensic triage identifies a locally staged file named similarly to “client_transition_export.csv” in the employee’s user profile. HR confirms the employee has accepted a role at a competitor. A limited review of messages and notes suggests the employee discussed “keeping client relationships warm,” but there is no evidence yet that any client data has been publicly posted, sold, or used for solicitation.

Confirmed facts

- The employee has accepted a role at a competitor, based on HR or manager records.
- The exported CRM data was staged locally on the managed workstation after download.
- The local file contains client identifiers matching the CRM export event.
- No known public posting, dark-web listing, or confirmed external sale has been found.
- Legal and HR have been engaged.

Suspected / likely facts

- The employee intended to use the client-book data after departure.
- The file may have been renamed or organized to reduce obvious detection.
- USB file transfer is more likely but still requires forensic validation or recovered media to confirm.

Working hypotheses

- The activity is attempted client poaching rather than broad cybercrime monetization.
- The employee may have already contacted selected clients using personal channels.
- The organization may need civil remedies even without confirmed public disclosure.
- Notification analysis may be required even if external publication is not confirmed, depending on loss-of-control assessment and jurisdiction.

Discussion questions

- Does the new evidence trigger a formal breach and notification assessment now, or only after confirmed external disclosure?
- What legal actions should be prepared immediately, and who approves them?
- Which client segments should be prioritized for impact analysis?
- How should executives be briefed without overstating facts?
- Should the organization contact the new employer, law enforcement, or regulators at this stage?

Expected actions

- Launch formal privacy, breach, and regulatory-notification assessment under Legal/Privacy leadership.
- Segment affected clients by geography, sensitivity, product type, relationship criticality, regulatory obligations, and contractual commitments.
- Prepare a privileged executive briefing that clearly separates confirmed facts, suspected facts, and open questions.
- Consider cease-and-desist, preservation demand, employment action, civil remedies, and law-enforcement referral options.
- Increase monitoring for client complaints, unusual outreach, competitor contact, dark-web mentions, personal email patterns, and external file-sharing activity.
- Define decision thresholds for client notification and regulator engagement.
- Reassess whether any other employees or entitlements present similar export risk.

Facilitator notes

This stage should push the conversation beyond technical containment. Encourage participants to identify what is legally confirmed, what is a reasonable investigative inference, and what cannot yet be stated to regulators, clients, managers, or the suspected employee.

Evaluation checkpoint

- Breach-notification assessment owner identified.
- Executive briefing format includes evidence confidence labels.
- Client-impact methodology described.
- Legal response options considered without prematurely contacting external parties.

Inject 4 - Decision Point: Contain, Notify, Escalate

Exercise time: 13:00

Inject

Forensic triage estimates that several hundred high-net-worth client profiles were included in the export. Data fields include names, contact information, servicing teams, relationship notes, product relationship summaries, and portfolio-related indicators. Endpoint artifacts show file staging and USB activity in close sequence, but the USB device has not yet been recovered. The organization must decide whether to notify clients, engage regulators, pursue legal remedies, and communicate to client-facing teams.

Confirmed facts

- Several hundred high-net-worth client records were exported from the CRM repository.
- The data includes personal contact information and relationship-sensitive business information.
- Local staging of the export file is confirmed.
- USB device connection is confirmed.
- No confirmed public posting, sale, external email transmission, or personal cloud upload has been identified.

Suspected / likely facts

- The staged file was copied to the USB device.
- Loss of control over client data may have occurred even without public disclosure.
- Some clients may be more sensitive due to jurisdiction, profile, relationship value, or confidential notes.

Working hypotheses

- Client notification may be required or advisable depending on jurisdiction and final loss-of-control assessment.
- Regulator pre-notification may reduce surprise and demonstrate governance maturity.
- Contacting the competitor or law enforcement could preserve evidence, but may also affect employee-rights and litigation strategy.

Discussion questions

- Who has authority to decide on client notification, regulator outreach, and external statements?
- What threshold determines whether clients are contacted now versus after additional forensic validation?
- What should relationship managers say if clients ask about unusual contact or mention the departing employee?
- What facts should be included in a regulator-ready chronology?
- How will the organization prevent inconsistent messaging across Security, HR, Legal, business leaders, and client-facing teams?

Expected actions

- Convene a cross-functional decision cell with clear decision rights: decision owner, legal adviser, technical fact owner, HR owner, privacy owner, business owner, communications owner.
- Approve a client-risk decision framework and notification criteria based on data sensitivity, loss-of-control likelihood, jurisdiction, contractual duties, and client-harm risk.
- Finalize legal hold, forensic acquisition, endpoint preservation, access revocation, and case-management steps.
- Prepare regulator-ready chronology: facts known, evidence source, confidence, actions taken, open questions, next steps, and decision rationale.
- Prepare client-facing and employee-facing communication lines approved by Legal, Communications, and business leadership.
- Define monitoring plan for delayed misuse: client complaints, unusual solicitation, dark-web references, external domains, personal email, and CRM access by other users.
- Decide whether to seek recovery of the USB device, request written preservation, or pursue civil/law-enforcement options.

Facilitator notes

Watch for governance clarity. Participants should identify who decides, who advises, and who executes. Challenge any group that treats the SOC as the owner of legal, HR, regulator, or client-notification decisions.

Evaluation checkpoint

- Decision cell convened and decision rights stated.
 - Notification criteria documented with thresholds.
 - Regulator-ready chronology contains fact confidence and evidence sources.
 - Client-facing message control established.
-

Inject 5 - Resolution and Aftermath

Exercise time: 15:00

Inject

The employee's access has been revoked, the laptop has been preserved, and immediate CRM export risk is contained. During HR and Legal engagement, the employee admits exporting client information for "transition reference" and acknowledges the future competitor role, but denies contacting clients or selling data. The USB device has not yet been recovered. Monitoring has found no public posting or confirmed external disclosure, but the organization must complete notification analysis, pursue legal remedies, monitor for downstream misuse, and document lessons learned.

Confirmed facts

- Employee access to CRM, mailbox, endpoint, collaboration tools, and remote access has been revoked or restricted.
- The managed laptop is preserved under chain of custody.
- Unauthorized export and local staging of client data are confirmed.
- The employee admitted the export but denied external disclosure.
- No public leak, sale, or confirmed client solicitation has been identified at this time.

Suspected / likely facts

- The client data may have left the organization through the unapproved USB device.
- The employee may have retained a copy despite denying external use.
- Delayed misuse may emerge after departure or after legal action begins.

Working hypotheses

- Civil action may be the most effective recovery and preservation path.
- Regulatory expectations may focus on governance, loss-of-control assessment, client-risk analysis, and control remediation.
- Insider-risk and offboarding controls may require immediate improvement beyond this single employee.

Discussion questions

- What are the next actions over the next 24 hours, 7 days, and 30 days?
- What post-incident reporting is required internally and externally?
- What evidence gaps remain, and who owns closing them?
- How should the organization monitor for delayed misuse of the client information?
- What control improvements are required in offboarding, access governance, DLP, USB controls, and abnormal export analytics?

Expected actions

- Produce an executive after-action summary with facts, decisions, impact, open risks, and remediation owners.
- Complete privacy, regulatory, contractual, and client-notification assessments with Legal and Compliance.
- Pursue recovery or preservation of any external media through appropriate legal channels.
- Monitor client complaints, suspicious outreach, competitor-contact patterns, dark-web mentions, and anomalous CRM activity.
- Review removable-media controls, data export approvals, least privilege, role-based access, offboarding triggers, and endpoint telemetry coverage.
- Update insider-risk playbooks to include confirmed/suspected/hypothesis logging and decision thresholds.
- Assign remediation owners, due dates, and executive oversight for control gaps.

Facilitator notes

The final phase should not end with technical containment. Push participants to define how they will prove closure, determine residual risk, communicate to governance bodies, and track control remediation to completion.

Evaluation checkpoint

- 24-hour, 7-day, and 30-day action plan produced.
- Residual-risk owner identified.
- Lessons learned converted into assigned remediation actions.
- Monitoring plan for delayed misuse defined.

Decision Points

Decision	Trigger / evidence to consider	Expected owner or decision forum
Classification	Confirmed sensitive CRM export, offboarding status, data types, volume, out-of-portfolio access, and policy violation indicators.	Incident Commander with Security, Legal, Privacy, HR, and business input.
Containment	Sensitive export confirmed; no clear business justification; employee in notice period; evidence of removable media or other exfiltration channel.	Security executes; Legal/HR advise on employee implications; business owner manages continuity.
Employee action	Risk of evidence destruction, continued access, employee rights, need for interview, legal hold, and preservation of devices or media.	HR and Legal decide; Security and management support.
Evidence handling	Need to preserve laptop, removable media, mailbox, CRM logs, IAM logs, DLP events, and cloud/proxy logs under chain of custody.	Digital Forensics and Legal; evidence custodian assigned.
Client notification	Data sensitivity, number of affected clients, loss-of-control likelihood, jurisdictional thresholds, client-harm risk, and relationship considerations.	Privacy/Legal/Compliance with executive and business approval.
Regulatory engagement	Materiality, jurisdiction-specific rules, confirmed facts, uncertain external disclosure, control weaknesses, and reputation risk.	Compliance/Legal with executive sponsorship.
Legal response	Need to preserve or recover data, stop use, compel return, notify new employer, or involve law enforcement.	Legal with HR, Security, and executive decision forum.
Communications	Need for consistent internal, client-facing, regulator-facing, and potential media messaging.	Communications with Legal, Privacy, Compliance, and business leadership.

Playbook Execution Criteria

Playbook step	Minimum execution criteria	Evidence to capture
Open insider-risk case	Sensitive data export by user in notice period or other high-risk population, above baseline or outside portfolio.	SIEM alert ID, CRM export event IDs, employee status, baseline comparison, case number.
Preserve evidence	Any confirmed sensitive export or endpoint/removable-media correlation.	Legal-hold notice, log retention request, endpoint preservation timestamp, evidence custodian, hash values when available.
Restrict access	No validated business justification plus confirmed sensitive export; immediate disablement if ongoing risk exists.	Access-change request, approval authority, systems restricted, timestamp, business-continuity workaround.

Playbook step	Minimum execution criteria	Evidence to capture
Endpoint isolation / acquisition	Need to prevent tampering or preserve volatile artifacts; balance against tipping off subject.	EDR isolation event, collection method, chain-of-custody form, forensic image status.
Employee engagement	Legal and HR approve interview plan, evidence preservation completed or in progress, manager role defined.	Interview plan, attendees, script boundaries, legal privilege marking, device recovery plan.
Notification assessment	Unauthorized access/export to personal or confidential client data, or credible loss-of-control indication.	Affected population, fields involved, jurisdictions, harm assessment, legal decision record.
External action	Evidence supports data retention/use outside authorized business purpose or urgent need to preserve external evidence.	Legal strategy, preservation demand, regulator advisory, law-enforcement referral decision, external communication approvals.

Business and Technical Impact Considerations

Impact area	Potential impact	Evidence / validation needed
Client trust	Loss of confidence among high-net-worth clients and relationship-sensitive segments.	Client list, relationship manager mapping, complaints, unusual client inquiries, outreach monitoring.
Competitive harm	Client poaching, misuse of relationship notes, or erosion of private-banking relationship value.	Competitor role confirmation, client-contact patterns, employee communications, client feedback.
Regulatory exposure	Scrutiny over confidentiality controls, access governance, incident response, and notification decision-making.	Regulator-ready chronology, policy mapping, control evidence, notification analysis.
Litigation and employment action	Civil remedies, employment discipline, evidence-preservation disputes, or law-enforcement referral.	Legal hold, chain of custody, employee admissions, device/media recovery status.
Technical control gaps	Weak removable-media control, excessive entitlements, insufficient DLP, incomplete endpoint telemetry, insufficient export approval.	Control configuration, alert coverage, logs, access reviews, exceptions, remediation backlog.
Operational disruption	Need to reassign client relationships, brief client-facing teams, and prevent inconsistent messaging.	Client coverage plan, relationship manager instructions, call center/client-service scripts.

Facilitator Prompts by Audience

Audience	Prompts
Executive audience	What is the organization's risk appetite for early client notification? What threshold makes this an enterprise crisis rather than an HR-led matter? What would the Board expect to know in the first briefing? Who approves regulator outreach and external statements?

Audience	Prompts
Operational audience	How are Legal, HR, Privacy, Compliance, Security, Communications, and the business synchronized in the first four hours? Which records are privileged? How are decisions documented for later defensibility? How do you avoid tipping off the subject before evidence is preserved?
Technical audience	What telemetry confirms data export volume, scope, and destination? Which logs prove local staging and USB copy? What controls exist for mass export, USB insertion, file copy, printing, email forwarding, and cloud upload? What are your gaps if endpoint telemetry or DLP is incomplete?
Business / Client-facing audience	Which relationship managers need instructions? How are client questions routed? What can be said if a client reports unusual contact? How are affected clients prioritized by sensitivity and relationship risk?

Evaluation Plan and Success Metrics

Observers should score each checkpoint using the rubric below and capture evidence of decisions, owners, and time-based actions. The exercise is successful when participants can make proportionate decisions under uncertainty, preserve evidence, coordinate functions, and produce a defensible narrative of facts and actions.

Score	Description
1 - Not demonstrated	Participants do not identify the required action, owner, or risk.
2 - Partially demonstrated	Participants discuss the issue but do not define an owner, decision threshold, evidence need, or timing.
3 - Adequate	Participants identify the correct action and owner but leave gaps in evidence handling, communications, or documentation.
4 - Strong	Participants make a policy-aligned decision, document rationale, identify evidence sources, assign owners, and coordinate cross-functionally.
5 - Leading practice	Participants demonstrate repeatable playbook execution, legal/HR/privacy coordination, evidence confidence discipline, measurable timelines, and clear executive/regulator-ready documentation.

Facilitator Checkpoints

Checkpoint	Observable behavior	Target outcome
Checkpoint 1: Initial triage	Team classifies incident, starts fact/hypothesis log, preserves logs, and notifies Legal/HR/Privacy as appropriate.	Severity and evidence-preservation plan documented within the first inject.
Checkpoint 2: Containment decision	Team chooses immediate restriction or controlled monitoring and documents rationale and risk tradeoffs.	Access/host/device strategy approved with decision owner and execution owner.

Checkpoint	Observable behavior	Target outcome
Checkpoint 3: Technical validation	Team identifies telemetry needed to prove or disprove USB transfer, local staging, cloud upload, email exfiltration, and printing.	Forensic and log-review workplan assigned.
Checkpoint 4: Governance decision cell	Team identifies who decides, advises, and executes for notification, legal action, employee action, and external communications.	Cross-functional decision cell established.
Checkpoint 5: Client/regulator readiness	Team develops regulator-ready chronology and client-risk framework with confidence labels.	Communication and notification criteria approved or escalated.
Checkpoint 6: Recovery and lessons learned	Team defines 24-hour, 7-day, and 30-day actions, residual risks, and remediation owners.	After-action actions assigned with due dates and executive oversight.

Measurable Success Criteria

- Within first 30 minutes of exercise time, participants identify at least five evidence sources and assign preservation ownership.
- By Inject 2, participants make a documented access and endpoint containment decision using explicit criteria.
- By Inject 3, participants initiate formal breach/notification assessment and identify client-impact segmentation factors.
- By Inject 4, participants produce a decision-rights model for client notification, regulator engagement, employee action, and communications.
- By exercise close, participants identify at least six control improvements with accountable owners and target due dates.
- Throughout the exercise, participants avoid presenting suspected USB transfer, client solicitation, or external disclosure as confirmed facts until evidence supports it.

Expected Good Practices

- Use predefined insider-risk criteria and severity thresholds.
- Preserve application, identity, endpoint, DLP, network, collaboration, and HR evidence early.
- Maintain a fact / suspected fact / hypothesis / decision log under appropriate privilege.
- Coordinate Security, Legal, HR, Privacy, Compliance, Communications, and business leadership before employee engagement.
- Avoid premature client, regulator, employee, or media statements.
- Document why containment is proportionate even where exfiltration is not fully confirmed.
- Define clear decision authority for notification, employment action, legal response, and external communication.
- Use client-impact analysis driven by data sensitivity, client residency, relationship value, and likelihood of misuse.

- Use ATT&CK mapping to improve detection coverage and control design, not to force unsupported conclusions.
- Convert lessons learned into owners, due dates, and governance tracking.

Debrief / Lessons Learned

Use the final 10-15 minutes to capture observations, assign follow-up ownership, and identify control improvements.

- What worked well in detection, escalation, and cross-functional coordination?
- Where were roles unclear or overlapping?
- Were Legal, HR, Privacy, and Compliance dependencies understood early enough?
- Would current tooling prove USB-based exfiltration, or only show correlation?
- Are offboarding controls proportionate for high-risk client-facing roles?
- Are bulk exports appropriately approved, logged, and reviewed?
- What evidence gaps would impair regulator or litigation readiness?
- What would the organization change in the next 30 days?

Suggested Improvement Actions

Control area	Recommended improvement	Priority
Offboarding governance	Trigger enhanced monitoring and access review when employees in sensitive roles enter resignation notice periods.	High
Abnormal export analytics	Implement thresholds for high-volume, out-of-portfolio, unusual-hour, and sensitive-field exports from client repositories.	High
Bulk export controls	Require enhanced approval, justification, logging, and DLP classification for large client-data exports.	High
Removable media	Block or restrict unapproved USB storage and alert on sensitive-file creation followed by removable-media activity.	High
Access governance	Review least privilege, role-based access, toxic combinations, and periodic entitlement reviews for private-banking roles.	High
Forensic readiness	Ensure endpoint telemetry can capture file creation, USB mount, file copy indicators, browser downloads, and chain-of-custody evidence.	Medium
Legal/HR/Security playbooks	Pre-build playbooks for insider cases, employee interviews, legal hold, device preservation, and civil remedies.	Medium

Control area	Recommended improvement	Priority
Client notification readiness	Exercise client-risk decision frameworks and pre-approved communications language before a real incident.	Medium
Monitoring for downstream misuse	Define monitoring for client complaints, competitor outreach, external mentions, dark-web references, and suspicious CRM access by others.	Medium

Mapping to the Source Structured Scenario

The exercise is derived from the uploaded structured scenario objects describing the following elements:

- a financial-services/private-banking organization;
- a departing or disgruntled insider with legitimate client-book access;
- a high-net-worth client data repository or CRM/client-book system;
- unusually large export activity using legitimate credentials;
- an unapproved external storage device as a potential exfiltration tool;
- an incident involving theft or attempted misuse of high-net-worth customer data;
- inject themes covering abnormal export activity, removable-media evidence, legal hold, client risk, and law-enforcement or civil-action considerations;
- courses of action related to abnormal export alerting, access restriction, legal/HR coordination, evidence preservation, and insider-risk case management.

MITRE ATT&CK Mapping

The mapping below is deliberately confidence-based. Techniques are mapped only where supported by the revised scenario facts. Items marked “suspected” should remain investigative leads until the evidence is confirmed. ATT&CK data-source terminology is retained for exercise usefulness, while recognizing that ATT&CK introduced detection strategies and deprecated legacy data sources in v18.

Scenario activity	ATT&CK tactic	Technique	Confidence	Evidence and detection procedures
Legitimate employee account used to access CRM and export records.	Initial Access / Defense Evasion / Persistence / Privilege Escalation	T1078 - Valid Accounts	Confirmed, with caveat	CRM and IAM logs show access using a valid relationship-manager account. Caveat: the scenario does not assert credential theft; the relevant behavior is abuse of authorized account access by an insider. Review IAM logs, MFA, impossible travel, session reuse, and account status.
Employee browses local export folders and organizes/renames client-export files before potential transfer.	Discovery	T1083 - File and Directory Discovery	Confirmed if endpoint artifacts show folder browsing; otherwise suspected	EDR, file-system artifacts, shellbags/jumplists, recent files, and process telemetry can show browsing of Downloads, export folders, and removable-media paths.
Employee mines and exports client records from the CRM/client-book repository.	Collection	T1213.004 - Data from Information Repositories: Customer Relationship Management Software	Confirmed	CRM application audit logs, report/export logs, API logs, query filters, report names, record counts, and DLP classification identify high-volume client-record access and export.
Exported CRM files are created on the managed workstation and become local files available for copying.	Collection	T1005 - Data from Local System	Confirmed for local handling after export	Endpoint telemetry, file creation events, browser download artifacts, local path evidence, and DLP endpoint events show sensitive data saved locally.
Exported client-book file is renamed and placed in a local folder before suspected transfer.	Collection	T1074.001 - Data Staged: Local Data Staging	Confirmed if local staging artifacts are present	File creation, rename, compression, path movement, MFT/USN journal, EDR file events, and DLP endpoint events demonstrate staging before exfiltration.

Scenario activity	ATT&CK tactic	Technique	Confidence	Evidence and detection procedures
Unapproved USB storage device is connected during the export window.	Exfiltration	T1052 - Exfiltration Over Physical Medium	Suspected / high confidence, not fully confirmed until transfer evidence or recovered media exists	Drive/removable-media telemetry, device serial number, mount events, EDR file writes, file-system artifacts, and recovered media analysis are required to confirm.
Potential copy of staged client-book file to removable media.	Exfiltration	T1052.001 - Exfiltration over USB	Suspected until proven	USB device insertion followed by high-volume or sensitive file access, file-write operations to removable drive, DLP alerts, USN journal evidence, and recovered USB contents would confirm this behavior.

ATT&CK-Informed Detection and Mitigation Prompts

- Can the organization detect high-volume access or export of customer records by users who rarely perform that activity?
- Can monitoring distinguish in-portfolio versus out-of-portfolio client access?
- Do SIEM rules correlate CRM export, DLP classification, endpoint file creation, and USB insertion within a defined time window?
- Can endpoint telemetry show file writes to removable media with serial number, user, process, filename, hash, and timestamp?
- Are DLP and endpoint controls configured to block or alert on sensitive customer information copied to unapproved removable media?
- Does offboarding automatically trigger enhanced monitoring, access review, and removal of export rights for high-risk roles?
- Are client repositories covered by least privilege, periodic access review, and bulk export approval workflows?
- Can investigators produce a regulator-ready chronology that ties each fact to an evidence source?

Techniques Considered but Not Asserted

Technique	Why it is not asserted by default	When it would become relevant
T1119 - Automated Collection	The baseline scenario involves standard CRM report exports, not proven scripting or automated collection.	Map if logs show scheduled reports, API scripting, ETL tools, command-line collection, or repetitive automated export jobs.
T1567 - Exfiltration Over Web Service	No confirmed personal cloud upload, webmail upload, or external file-sharing transfer is present.	Map if proxy/CASB/DLP logs show upload to personal cloud, webmail attachment, or external collaboration platform.
T1041 - Exfiltration Over C2 Channel	No malware, command-and-control channel, or remote operator is present.	Map only if malware/C2 evidence emerges.

Technique	Why it is not asserted by default	When it would become relevant
T1003 - OS Credential Dumping	The scenario does not involve stolen credentials or credential dumping.	Map only if forensic evidence shows credential theft tools, LSASS access, or harvested secrets.
T1027 - Obfuscated Files or Information	File rename alone is not enough to assert obfuscation.	Map only if compression, encryption, encoded files, or deliberate concealment is confirmed.

ATT&CK-Linked Control Review Questions

Control theme	Questions for participants
Account misuse	How quickly can IAM identify users in notice period with sensitive-role access? Are export privileges removed or reviewed during offboarding?
Discovery and local handling	Can endpoint telemetry reconstruct local file browsing, downloads, renames, compression, and staging folders?
CRM collection	Are CRM export fields and record counts logged? Are abnormal report filters and out-of-portfolio exports alerted?
Local staging	Do endpoint and DLP tools label sensitive exports after download? Are local staging folders monitored for sensitive files?
USB exfiltration	Are unapproved USB devices blocked? If allowed, are filename, hash, serial number, and write events captured?
Residual monitoring	Can the organization monitor for client outreach, complaints, dark-web references, competitor contact, and delayed misuse after containment?

Source References

- Uploaded source exercise: test_06.pdf.
- Uploaded evaluation feedback: test_06_con_eval.json.
- MITRE ATT&CK Enterprise technique T1078 - Valid Accounts.
- MITRE ATT&CK Enterprise technique T1083 - File and Directory Discovery.
- MITRE ATT&CK Enterprise technique T1005 - Data from Local System.
- MITRE ATT&CK Enterprise technique T1074.001 - Data Staged: Local Data Staging.
- MITRE ATT&CK Enterprise technique T1213.004 - Data from Information Repositories: Customer Relationship Management Software.
- MITRE ATT&CK Enterprise techniques T1052 and T1052.001 - Exfiltration Over Physical Medium / Exfiltration over USB.
- MITRE ATT&CK detection strategies DET0550 - Detecting Suspicious Access to CRM Data in SaaS Environments and DET0220 - Detection of USB-Based Data Exfiltration.
- MITRE ATT&CK Data Sources reference, noting v18 deprecation of legacy data sources.

Acronym and Term Glossary

Term	Definition
ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge framework.
CRM	Customer Relationship Management system; in this exercise, the client-book repository for private-banking relationships.
DLP	Data Loss Prevention controls and telemetry used to detect or restrict movement of sensitive information.
EDR	Endpoint Detection and Response telemetry used to investigate endpoint behavior, file activity, and device activity.
IAM	Identity and Access Management function responsible for account access, entitlements, MFA, and revocation.
SIEM	Security Information and Event Management platform used to correlate logs and alerts.
SOC	Security Operations Center responsible for monitoring, triage, and incident coordination.
USB	Universal Serial Bus removable media; in this scenario, an unapproved external storage device.
Legal hold	A preservation process requiring relevant records and evidence to be retained for legal, regulatory, or investigative needs.
Fact / hypothesis log	A working incident record that separates validated evidence from suspected facts and investigative theories.